

# Enumeracion de SMB

## Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

## Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

## Fundamentos técnicos

SMB (445, y 139) es el protocolo de compartición de ficheros de Windows. Enumerarlo consiste en listar sus shares (carpetas compartidas), ver a cuáles puedes acceder sin o con credenciales, y sacar información del sistema y del dominio. Es una de las superficies más rentables en rooms Windows/AD.

Muchas configuraciones permiten sesión nula o de invitado, dejando shares legibles con backups, configs o credenciales. Y aunque no haya acceso anónimo, SMB filtra el nombre del equipo, el dominio y a veces la lista de usuarios, que alimentan el resto del ataque (spraying, kerberos).

## Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final  
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

## Superficie de ataque

Siempre que el recon muestre 445 abierto. Es de las primeras cosas a enumerar; en un DC además se combina con LDAP y Kerberos (ad-modelo).

## Cómo identificarla

- nmap marca 445/tcp open microsoft-ds o el script smb saca el dominio.
- Un share con permiso READ que no sea IPC\$ (a menudo backups, transfer, dev).
- Sesión nula/guest aceptada: puedes listar sin credenciales.

## Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

## Prueba mínima

nxc smb \$IP -u " " -p " --shares para probar sesión nula.

Evidencia esperada: Columna READ/WRITE por share; un READ fuera de IPC\$ es acceso real. El header confirma nombre de equipo y dominio.

## Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.

3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

## Capa 1: prueba documentada

```
nxc smb $IP -u '' -p '' --shares
```

Objetivo y contexto: Comprueba sesión nula y lista los shares de golpe. Es la prueba más rentable en SMB: un share legible te ahorra toda la fase de explotación.

Resultado esperado: Columna READ/WRITE por share. Un READ fuera de IPC\$ es saqueo directo. El encabezado también confirma nombre de equipo y dominio.

## Capa 2: prueba documentada

```
nxc smb $IP -u 'guest' -p '' --rid-brute
```

Objetivo y contexto: Si hay acceso guest/nulo, itera los RID para sacar la lista de usuarios del dominio sin credenciales. Necesitas usuarios válidos antes de rociar passwords.

Resultado esperado: Líneas SidTypeUser = usuarios reales. Extrae los nombres (sin las cuentas de máquina terminadas en \$) a users.txt para spraying y roasting.

## Anatomía de los payloads

La primera prueba es `nxc smb $IP -u '' -p '' --shares`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

## Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

## Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

## Evidencias de confirmación

Columna READ/WRITE por share; un READ fuera de IPC\$ es acceso real. El header confirma nombre de equipo y dominio.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

## Escalado de impacto

- Comprueba acceso anónimo listando shares con usuario vacío o guest.
- Entra a cada share legible y saquea configs, backups y ficheros de usuario.
- Si tienes credenciales, repite: suele abrir más shares y, si eres admin local, ejecución.
- Extrae usuarios (rid-brute) para alimentar spraying y roasting en AD.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

## Errores frecuentes

- SMB firmado y sin sesión nula/guest, y no tienes ninguna credencial que probar.

- El servicio en 445 no es realmente SMB (honeypot o servicio remapeado).
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

## Diagnóstico de payloads fallidos

| Síntoma              | Posible causa                  | Prueba de diagnóstico         | Adaptación                 |
|----------------------|--------------------------------|-------------------------------|----------------------------|
| Rechazo inmediato    | Formato o precondition         | Repetir entrada válida        | Corregir transporte        |
| Sin diferencia       | Entrada ignorada o canal ciego | Marcador y control negativo   | Buscar evidencia adecuada  |
| Error del componente | Contexto o versión             | Reducir a prueba mínima       | Consultar manual detectado |
| Resultado parcial    | Permisos/restricción           | Comprobar identidad y alcance | Reducir primitiva          |

## Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

## Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

## Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

## Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

## Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

## Resumen

El puerto 445 suele regalar shares legibles, nombres de usuario y el dominio; comprueba siempre el acceso anonimo primero. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

## Chuleta operativa

1. Confirmar alcance y condiciones.
2. Identificar entrada, componente y permisos.

3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

## Referencias

- [Concepto fuente de THM Fieldbook \(smb-enum\)](#)
- [Referencia técnica externa](#)

## Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.